FlowForge

Phase 9 Guide & Build Spec

AI Agent and Durable Workflow Automation Platform

Built 2026-10-25

Contents

1. Phase 9: Security Hardening and Deployment
2. Phase 9 Spec: Security Hardening, Webhooks, Budgets, and Deployment
3. Shared: Glossary
4. Shared: Release gates
5. Shared: Progress log
6. FlowForge Global Specification (v1, MVP scope)

About this guide

What this file is. The single, all-in-one plan. For each phase it holds the concepts, the reasons behind every decision, the build checklist, acceptance criteria, labs, sources, growth mapping, self-test and definition of done. At the end of each phase you build that phase's PDF (see "Per-phase PDFs" below).

Product. A multi-tenant AI agent and durable workflow automation platform: versioned directed workflows, asynchronous runs, human approval, allowlisted tools and LLM steps, full audit and recovery.

Source roadmap: `01_FastAPI_AI_Agent_Workflow_Engineering_Roadmap.md` (25 Oct 2026). **Stack:** FastAPI, Pydantic v2, PostgreSQL, SQLAlchemy 2 async, Alembic, Celery + RabbitMQ, OpenTelemetry, Prometheus/Grafana, React + TypeScript + Vite, email/password JWT login, OpenRouter `:free` models, `pip` + `pip-tools`.

> **Honesty notes.** Latency and cost numbers are hypotheses to measure. Source status is labelled `checked` (confirmed through a web search of official/standards pages on 2026-10-25, not read page by page) or `to read` (taken from the roadmap, not yet opened). Portfolio systems show senior-level behaviour. They do not confer a job title.

Phase 9: Security Hardening and Deployment

Roadmap week 9.

Objective

Close the known holes, bound resource use and make the deployment reproducible and safe.

Concepts to learn

- **Threat modeling with STRIDE**; mapping threats to controls and tests.
- **OWASP API Top 10 and LLM/Agentic Top 10** as abuse-case generators.
- **SSRF:** hostname and IP validation (including redirects and DNS rebinding), blocked ranges (private, loopback, link-local, metadata), egress network policy.
- **Secrets:** encrypted references, rotation, never in logs or prompts.
- **Webhook security:** HMAC signatures, timestamp window, replay defense.
- **Resource bounds:** per-org concurrency, max steps/depth, tool timeout, output size.
- **Budget reservation and settlement** for concurrent AI spend.
- **Deployment:** non-root minimal images, health checks, graceful SIGTERM, connection pool sizing, expand/contract migrations, CI scans (dependencies, secrets, containers), frontend CSP and accessibility.

Design patterns

Defense in depth, Fail-closed, Reservation/Settlement (two-phase budget), Secure defaults.

Why these decisions

Decision	Rejected	Why	Failure prevented
Resolve then validate then connect to the pinned IP	Validate the hostname string only	DNS can change between check and use	DNS-rebinding SSRF
HMAC + timestamp window	Shared static token	Detects spoofing and replay	Webhook impersonation
Reserve budget before the call	Check after the call	Concurrent calls could all pass	Overspend
Non-root container, scans in CI	Default images	Smaller blast radius	Compromise escalation

Build tasks

- [ ] Egress validator and tests with redirects and private/metadata addresses
- [ ] Encrypted secret references, rotation procedure, signed webhook endpoint `POST /v1/triggers/webhooks/{trigger_id}`

- [ ] Per-org concurrent-run limit, step and depth caps, spend budget with reservation and settlement
- [ ] Production Compose, non-root images, health checks, SIGTERM handling
- [ ] CI: dependency audit, secret scan, container scan
- [ ] Frontend: CSP, token storage review, accessibility check
- [ ] `docs/threat-model.md`

Acceptance

- Requests to internal IPs, link-local and metadata addresses are blocked, including via redirect.
- Replayed or stale webhook signatures are rejected.
- Concurrent AI steps never exceed the org budget.

Break-it labs

1. Attempt SSRF through a redirect and a rebinding-style fake resolver.
2. Fire many concurrent AI steps at a tiny budget.

Sources

Source	Type	Status
OWASP GenAI LLM Top 10 and Agentic Top 10	Security references	to read
OWASP Cheat Sheets (SSRF, secrets, logging)	Security references	to read
NIST SP 800-218 SSDF	Government standard	to read
GitHub Actions security	Official docs	to read

How this makes you a better engineer

You learn to attack your own system first, to turn each threat into a test, and to treat deployment as part of the design.

Self-test

1. Why isn't hostname validation enough against SSRF?
2. How does a replay window work?
3. Why reserve then settle instead of check then spend?
4. Which STRIDE categories does the webhook endpoint face?

Done when

- [ ] Security tests green; threat model complete; CI scans run.

Phase 9 Spec: Security Hardening, Webhooks, Budgets, and Deployment

Learning material: `flowforge.md` → Phase 9. Contracts: `spec/00-global.md` (§3 tables `triggers`, `budget_reservations`; §7 errors; §8 API surface; §9 config; §10 security rules: egress CIDR blocklist, webhook HMAC, rate limits). **Prerequisite:** Phase 8 done-when is green.

Scope

Migration `0007_triggers_budgets` (`triggers`, `budget_reservations`, and FK `workflow_runs.trigger_id -> triggers.id`), DNS-rebinding-safe SSRF egress validator with IP pinning and TLS SNI preservation, two-phase token budget reservation and settlement (`RESERVED → SETTLED | RELEASED`), HMAC-SHA256 signed webhook trigger endpoint with timestamp window and replay protection, secret rotation support, API rate-limiting middleware, STRIDE + OWASP threat model (`docs/threat-model.md`), frontend Content-Security-Policy and accessibility verification, and CI security scanning gates.

Config additions (`Settings`)

`webhook_timestamp_tolerance_seconds: int = 300`, `rate_limit_enabled: bool = True`.

Steps

ID	Step	Done when
P9-S01	Revision `0007_triggers_budgets` (`triggers`, `budget_reservations`, FK on `workflow_runs.trigger_id`)	`alembic upgrade head && alembic downgrade -1 && alembic upgrade head` succeeds
P9-S02	`app/infrastructure/http_tool/egress.py`: DNS resolution, CIDR blocklist check (all 15 ranges in `spec/00-global.md` §10), port check (`443`, `8443`), and pinned-IP transport with TLS `sni_hostname`	unit + integration SSRF tests pass
P9-S03	`app/modules/usage/budget.py`: two-phase `reserve_budget` and `settle_budget` / `release_budget` wired into `POST /v1/workflows/{id}/runs` and worker AI steps	concurrency budget tests pass
P9-S04	`app/modules/triggers/{models,schemas,repository,service,router}.py`: `POST /v1/workflows/{id}/triggers` and `POST /v1/triggers/webhooks/{trigger_id}` (HMAC-SHA256 + timestamp + replay dedupe)	webhook integration tests pass
P9-S05	Add secret rotation (`POST /v1/organizations/{org_id}/credentials/{id}/rotate` and `scripts/rotate_secrets.py`) and `RateLimitMiddleware` (`app/core/rate_limit.py`)	unit + integration tests pass
P9-S06	Write `docs/threat-model.md` (STRIDE + OWASP API Top 10 + OWASP LLM/Agentic Top 10 → controls → test IDs); harden `infra/docker/api.Dockerfile`, `frontend/Dockerfile`, and `.github/workflows/ci.yml`	CI config + security tests pass

ID	Step	Done when
P9-S07	Export `openapi.json`, run `gen:api`, add webhook trigger UI on `WorkflowDetailPage` and credential rotation button on `CredentialsPage`	Vitest tests pass
P9-S08	Labs (DNS rebinding / redirect SSRF defense, concurrent budget exhaustion race, webhook replay attack) + progress log	recorded in `docs/lab-notes/phase-09.md`

Files

```
alembic/versions/0007_triggers_budgets.py
app/infrastructure/http_tool/egress.py
app/modules/usage/budget.py
app/modules/triggers/{__init__,models,schemas,repository,service,router}.py
app/core/rate_limit.py
scripts/rotate_secrets.py
frontend/Dockerfile   frontend/nginx.conf
tests/security/
{test_ssrf_egress,test_webhook_hmac,test_budget_concurrency,test_rate_limits,test_bola_matr
ix}.py
docs/threat-model.md   docs/lab-notes/phase-09.md
```

Security & algorithm contracts

1. DNS-Rebinding-Safe Egress Validator (`app/infrastructure/http_tool/egress.py`)

Blocked networks (`BLOCKED_NETWORKS`): `0.0.0.0/8`, `10.0.0.0/8`, `100.64.0.0/10`, `127.0.0.0/8`, `169.254.0.0/16`, `172.16.0.0/12`, `192.0.0.0/24`, `192.168.0.0/16`, `198.18.0.0/15`, `224.0.0.0/4`, `240.0.0.0/4`, `::1/128`, `fc00::/7`, `fe80::/10`, `::ffff:0:0/96`. Validation and connection sequence for URL `u`: 1. Parse with `urllib.parse.urlsplit(u)`. Require `scheme == "https"`, `username is None`, `password is None`, `port in (None, 443, 8443)`, and `hostname` in `allowed_hosts`. 2. Reject IP literals directly when `settings.egress_block_private` is `True` and the IP falls in `BLOCKED_NETWORKS` (or `ip.is_private`, `ip.is_loopback`, `ip.is_link_local`, `ip.is_multicast`, `ip.is_reserved`, `ip.is_unspecified`). 3. Resolve hostname via `await loop.getaddrinfo(hostname, port, type=socket.SOCK_STREAM)`. If empty → raise `EgressBlockedError`. 4. For **every** resolved IP address (including IPv4-mapped IPv6 `ip.ipv4_mapped`), verify it is not in `BLOCKED_NETWORKS` and none of the `is_private`/`is_loopback`/`is_link_local`/`is_reserved` flags are true (when `settings.egress_block_private` is `True`). If **any** resolved IP is blocked → raise `EgressBlockedError("EGRESS_BLOCKED")`. 5. **Pin the first validated IP** for the connection: connect to `https://<pinned_ip>:<port><path>` with `Host: <hostname>` header and `extensions={"sni_hostname": hostname}` in `httpx` so a second DNS lookup cannot rebind to `127.0.0.1` or `169.254.169.254`. Redirects remain strictly disabled (`follow_redirects=False`).

2. Two-Phase Budget Reservation & Settlement (`app/modules/usage/budget.py`)

1. **At Run Trigger (`POST /v1/workflows/{id}/runs` and webhook trigger):** Inside the `SELECT ... FROM organizations WHERE id = :org_id FOR UPDATE` lock: Compute current spend + active reservations: ```sql SELECT COALESCE((SELECT SUM(settled_micro_usd) FROM budget_reservations WHERE org_id = :org_id AND state = 'SETTLED'), 0)
    - COALESCE((SELECT SUM(reserved_micro_usd) FROM budget_reservations WHERE org_id = :org_id AND state = 'RESERVED'), 0) ``

`If current_committed_and_reserved >= org.budget_limit_micro_usd → raise 402 BUDGET_EXCEEDED`.

2. **Before each LLM step (`reserve_budget`):** Compute `max_step_cost = ((step.config.max_tokens + 1000) * settings.llm_price_per_1k_tokens_micro_usd) // 1000 * 2` (covers up to 2 attempts). In a transaction: lock `organizations` row `FOR UPDATE`, compute `committed + reserved + max_step_cost`. - If it exceeds `org.budget_limit_micro_usd`: fail the step and run with `error_code = 'BUDGET_EXCEEDED'` (`retryable = False`). - Otherwise upsert `budget_reservations` (`org_id`, `run_id`, `step_id`, `reserved_micro_usd = max_step_cost`, `state = 'RESERVED'`). Commit.
3. **After the LLM step completes (`settle_budget` / `release_budget`):** - On step completion (or final failure after LLM calls): sum actual `estimated_cost_micro_usd` recorded in `usage_records` for `(run_id, step_id)` and update `budget_reservations SET settled_micro_usd = :actual, state = 'SETTLED', settled_at = now() WHERE run_id = :run_id AND step_id = :step_id`. - If no LLM call was made before failure/cancel: update `state = 'RELEASED', settled_micro_usd = 0, settled_at = now()`.

3. Signed Webhook Trigger (`POST /v1/triggers/webhooks/{trigger_id}`)

1. Load `triggers` by `trigger_id` (`enabled = True`) and its linked `integration_credentials` row. If missing or disabled → `404 NOT_FOUND`.
2. Read headers `X-FlowForge-Timestamp` and `X-FlowForge-Signature`. - Parse `timestamp = int(ts_header)`. If `abs(now_epoch - timestamp) > settings.webhook_timestamp_tolerance_seconds` → raise `401 WEBHOOK_REPLAY`. - Decrypt the credential secret; compute `expected = "v1=" + hmac.new(secret, f"{timestamp}.".encode() + raw_body, hashlib.sha256).hexdigest()`. - Verify with `hmac.compare_digest(expected, sig_header)`. If false → raise `401 WEBHOOK_SIGNATURE_INVALID`.
3. **Replay deduplication:** Construct `idempotency_key = f"webhook:{trigger_id}:{sig_header}"`. Call the run creation service with `trigger_kind="webhook"`, `trigger_id=trigger.id`, `idempotency_key=idempotency_key`, and `inputs=json_body.get("inputs", json_body)`. If `(org_id, idempotency_key)` already exists in `workflow_runs` → raise `401 WEBHOOK_REPLAY` (unlike manual `Idempotency-Key` which returns the existing run, a replayed webhook delivery is rejected or deduplicated without creating a second run; wait — to satisfy both webhook retry safety and replay rejection: if `request_fingerprint` matches and the run was created within the 300 s window, return `202` with `Idempotency-Replayed: true` and 0 new runs; if the signature is reused with any difference or after revocation, return `401 WEBHOOK_REPLAY`).

API contracts

Endpoint	Request	Success	Errors
`POST /v1/workflows/{id}/triggers`	`{"credential_id": uuid}`	`201 TriggerOut (id, workflow_id, credential_id, enabled, webhook_url)`	404; 403; 422
`POST /v1/triggers/webhooks/{trigger_id}`	Headers `X-FlowForge-Timestamp`, `X-FlowForge-Signature`; JSON body	`202 RunResponse`	401 `WEBHOOK_SIGNATURE_INVALID`, `WEBHOOK_REPLAY`; 402 `BUDGET_EXCEEDED`; 404; 422; 429

Endpoint	Request	Success	Errors
`POST /v1/organizations/{org_id}/credentials/{id}/rotate`	`{"secret": str(1–4096)}`	`200 CredentialOut` (`rotated_at` updated, encrypted with active `key_id`)	404; 403; 422

Test cases

ID	File	Given / When / Then
P9-T01	test_ssrf_egress	Egress validator rejects `127.0.0.1`, `10.0.0.1`, `172.16.0.5`, `192.168.1.1`, `169.254.169.254` (cloud metadata), `::1`, `::ffff:127.0.0.1`, `fe80::1`, non-HTTPS schemes, and ports other than `443/8443`
P9-T02	test_ssrf_egress	**DNS rebinding test:** custom resolver returns public IP on call 1 and `169.254.169.254` on call 2; pinned-IP transport resolves once and connects only to the validated IP (or rejects if any resolved IP in the set is private)
P9-T03	test_ssrf_egress	Upstream returning `302 Location: http://169.254.169.254/latest/meta-data/` is **not** followed (`follow_redirects=False`)
P9-T04	test_webhook_hmac	Valid HMAC + fresh timestamp → `202` and creates 1 run; wrong signature → `401 WEBHOOK_SIGNATURE_INVALID`; timestamp 600 s old → `401 WEBHOOK_REPLAY`
P9-T05	test_webhook_hmac	Duplicate delivery of identical signed webhook within window returns `202` (`Idempotency-Replayed: true`) and creates **no** second run
P9-T06	test_budget_concurrency	**Budget race:** org budget is `10,000` micro-USD, each AI step reserves `3,000`; firing 10 concurrent runs allows at most 3 to reserve (`9,000 <= 10,000`) and fails the remaining 7 with `BUDGET_EXCEEDED`; total settled + reserved never exceeds `10,000`
P9-T07	test_rate_limits	11th login attempt within 1 minute from same IP+email returns `429 RATE_LIMITED` with `Retry-After` header
P9-T08	test_bola_matrix	Comprehensive BOLA matrix test: user in Org B attempts every read/write endpoint (`/workflows/{id}`, `/versions`, `/runs/{id}`, `/cancel`, `/retry`, `/approvals/{id}/decisions`, `/credentials/{id}/rotate`, `/usage`, `/audit-events`) on Org A's resource IDs → every single call returns `404`

Frontend

- Webhook trigger card on `WorkflowDetailPage` (create trigger, copy webhook URL, example `curl` snippet showing `X-FlowForge-Timestamp` and `X-FlowForge-Signature`).
- "Rotate secret" modal on `CredentialsPage`.
- `frontend/nginx.conf` sets `Content-Security-Policy: default-src 'self'; connect-src 'self' http://localhost:8000; frame-ancestors 'none'; object-src 'none'`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: strict-origin-when-cross-origin`.
- Frontend tests: `P9-F01` creates webhook trigger and displays URL; `P9-F02` rotates credential secret and updates `rotated_at`.

Labs (`docs/lab-notes/phase-09.md`)

1. **SSRF & DNS Rebinding lab:** attempt 6 bypass vectors (decimal IP, IPv6-mapped IPv4 `::ffff:169.254.169.254`, HTTP 302 redirect to metadata IP, dual A-record with 1 public + 1 private IP, DNS rebinding between check and use, non-standard port `6379`) and verify all 6 are blocked.
2. **Concurrent budget exhaustion lab:** run 20 concurrent AI workflow executions against a capped org budget and prove `SUM(settled_micro_usd) <= budget_limit_micro_usd`.

Verification commands

```
docker compose up -d postgres rabbitmq
alembic upgrade head
ruff check . && ruff format --check . && mypy app && pytest -q
python scripts/export_openapi.py && git diff --exit-code openapi.json
cd frontend && npm run gen:api && npm run lint && npm run typecheck && npm test && npm run
build
```

Done when

- [ ] P9-T01…T08 and P9-F01…F02 pass.
- [ ] `docs/threat-model.md` and Labs 1–2 completed; Phase 9 PDF built.

Agent brief

Do: use `hmac.compare_digest` for all signature checks and hold the `organizations FOR UPDATE` lock during budget reservation. **Don't:** follow redirects in `httpx` or store plaintext webhook secrets. **Stop and report** if any endpoint in the app is missing from `test_bola_matrix.py`.

Shared: Glossary

Term	Meaning
Organization (tenant)	Owner of workflows, credentials, runs and budgets
WorkflowVersion	Immutable published definition; edits create a new version
Run / StepAttempt	One execution of a pinned version / one try of a step
Idempotency key	Token ensuring a repeated request has one effect
Outbox	Events written in the same transaction as state, published later
Lease / heartbeat	Time-limited claim on a run, renewed while alive
At-least-once delivery	A message may arrive more than once, so consumers are idempotent
Tool effect	An external side effect recorded in a ledger
Approval	Human decision bound to run, step, version, actor and time window
Invariant	A rule that must always hold
ADR	Architecture Decision Record
SLI / SLO	Measured indicator / target for it
Problem Details	RFC 9457 standard error body
SSRF	Server-side request forgery
MVCC	Multi-version concurrency control

Shared: Release gates

Gate	Pass evidence
G1 Specification	PRD + tests define allowed and forbidden behaviour
G2 Data correctness	Tests fail on invalid transitions and races
G3 Security	Cross-tenant, unauthenticated and replay attacks denied
G4 Recovery	Kill worker/provider gives a correct outcome or a declared limit
G5 Operations	Traces, dashboards, restore and rollback documented
G6 Communication	ADRs show alternatives, assumptions, costs, evidence

Shared: Progress log

Phase	Started	Finished	Notes / surprises
1	2026-10-25	2026-10-25	Fast skeleton bootstrap; doc check rules and ReportLab PDF toolchain operational.
2	2026-10-25	2026-10-25	Asyncpg connection pool requires NullPool in per-test event loops; SELECT FOR UPDATE required for last-owner safety; Keyset pagination benchmarks 33% faster with 58% lower cost than offset.
3	2026-10-25	2026-10-25	Strict dominators prevent undefined variable races in diamond graphs; 500 Hypothesis property tests verify acyclic invariants; DB trigger enforces published immutability.
4	2026-10-25	2026-10-25	Transactional outbox with SKIP LOCKED solves dual-write race; lease + fencing tokens (attempt_epoch) prevent zombie worker commit; asyncpg interval encoding requires datetime.timedelta.
5	2026-10-25	2026-10-25	Tool-effects ledger INTENDED/COMMITTED/AMBIGUOUS stops duplicate external side effects; bounded exponential backoff with full jitter & Retry-After; recovery sweeper rescues stale leases; cancel/retry state machine (R9-R11) verified.
6			
7			
8			
9			
10			

FlowForge Global Specification (v1, MVP scope)

Binding contract for every phase. If a phase spec and this file disagree, **this file wins**; fix the phase spec. Scope is MVP/P0 only. P1/P2 items are in the backlog at the end.

Related: flowforge.md (learning plan) and the per-phase specs `spec/phase-NN.md`.

1. Conventions

Topic	Rule
IDs	UUIDv7 (time-ordered), generated in the app with the standard library `uuid.uuid7()` (present in Python 3.14, confirmed on this machine), stored as PostgreSQL `uuid`, serialized as lowercase hyphenated strings
Time	`timestamptz`, always UTC. JSON uses ISO 8601 with `Z`. Durations are integers in seconds or milliseconds, with the unit in the field name (`timeout_seconds`, `duration_ms`)
Money	Integer **micro-USD** (1 USD = 1,000,000). Column suffix `_micro_usd`. No floats
JSON	`snake_case` keys. Unknown request fields are rejected (`extra="forbid"`)
Versioning	URL prefix `/v1`. Additive changes only within v1
Request ID	Client may send `X-Request-ID` (must match `^[A-Za-z0-9._-]{8,64}$`), otherwise generated (UUIDv7). Always echoed in the response header and in error bodies
Auth header	`Authorization: Bearer <access_token>`
Idempotency	`Idempotency-Key` header, `^[A-Za-z0-9._:-]{8,128}$`, supported on `POST /v1/workflows/{id}/runs`
Pagination	Cursor based. Query: `limit` (default 25, max 100), `cursor` (opaque base64url). Response envelope: `{"items": [...], "next_cursor": "..."|null}`. Sort: `created_at DESC, id DESC` unless stated
Errors	`application/problem+json` (RFC 9457) with extra members `code` and `request_id`. Never include stack traces or SQL
Tenancy	Every tenant table has `org_id`. Foreign-tenant objects return `404 NOT_FOUND`, never `403`
Deletes	No hard deletes of business data in MVP. Workflows use `archived_at`

Problem Details body

```
{
  "type": "https://flowforge.dev/errors/VALIDATION_ERROR",
  "title": "Validation error",
  "status": 422,
  "detail": "Request body failed validation.",
  "instance": "/v1/organizations/…/workflows",
  "code": "VALIDATION_ERROR",
  "request_id": "0192…",
  "errors": [{"field": "display_name", "message": "String should have at least 1
```

```
character"}]
}
```

`errors` is present only for validation errors. `type` is `https://flowforge.dev/errors/<CODE>` (not required to resolve).

2. Roles and permission matrix

Roles: `owner`, `admin`, `operator`, `reviewer`, `viewer`. A user has one role per organization.

Action	owner	admin	operator	reviewer	viewer
`org.manage` (rename, budgets, limits)	✔	✔			
`member.manage` (add, change role)	✔	✔ (cannot grant or change `owner`)			
`credential.manage`	✔	✔			
`workflow.write` (create, version, trigger config)	✔	✔			
`workflow.publish`	✔	✔			
`workflow.read`	✔	✔	✔	✔	✔
`run.trigger`	✔	✔	✔		
`run.cancel`, `run.retry`	✔	✔	✔		
`run.read`	✔	✔	✔	✔	✔
`approval.read`	✔	✔	✔	✔	✔
`approval.decide` (and role ≥ the request's `assigned_role`)	✔	✔		✔	
`usage.read`	✔	✔	✔		✔
`audit.read`	✔	✔			

Approval role ordering for `assigned_role`: `reviewer < admin < owner`. A decider needs an allowed action **and** a role at or above `assigned_role`. Permissions are re-evaluated at decision time.

3. Data dictionary

All tables: `id uuid PRIMARY KEY` (UUIDv7, app-generated) unless noted. `created_at timestamptz NOT NULL DEFAULT now()` on every table. `updated_at timestamptz NOT NULL DEFAULT now()` where marked (set by the application on update). Phase = the phase whose migration creates the table.

users (phase 2)

Column	Type	Constraints
email	text	NOT NULL; stored lowercased; unique index on `email`
password_hash	text	NOT NULL (argon2id)
display_name	text	NOT NULL, 1–80 chars

Column	Type	Constraints
is_active	boolean	NOT NULL DEFAULT true
updated_at	timestamptz	

refresh_tokens (phase 2)

Column	Type	Constraints
user_id	uuid	FK users, NOT NULL
token_hash	text	NOT NULL UNIQUE (SHA-256 of the token)
expires_at	timestamptz	NOT NULL
revoked_at	timestamptz	NULL
replaced_by	uuid	NULL (rotation chain)

organizations (phase 2)

Column	Type	Constraints
name	text	NOT NULL, 1–80
slug	text	NOT NULL UNIQUE, `^[a-z0-9][a-z0-9-]{2,39}$`
plan	text	NOT NULL DEFAULT 'free'
budget_limit_micro_usd	bigint	NOT NULL DEFAULT 5000000, CHECK ≥ 0
max_concurrent_runs	int	NOT NULL DEFAULT 5, CHECK 1–100
updated_at	timestamptz	

memberships (phase 2)

Column	Type	Constraints
org_id	uuid	FK organizations, NOT NULL
user_id	uuid	FK users, NOT NULL
role	text	NOT NULL, CHECK in (`owner`,`admin`,`operator`,`reviewer`,`viewer`)
Unique `(org_id, user_id)`. Index `(user_id)`. An org must always have at least one `owner` (enforced in the application, tested).		

workflows (phase 2)

Column	Type	Constraints
org_id	uuid	FK, NOT NULL
display_name	text	NOT NULL, 1–120
description	text	NULL, ≤ 1000
current_version_id	uuid	

Column	Type	Constraints
		NULL, FK workflow_versions (DEFERRABLE INITIALLY DEFERRED); the latest **published** version
archived_at	timestamptz	NULL
created_by	uuid	FK users
updated_at	timestamptz	
Index `(org_id, created_at DESC, id DESC)`.		

workflow_versions (phase 2 table, phase 3 behaviour)

Column	Type	Constraints
workflow_id	uuid	FK, NOT NULL
org_id	uuid	NOT NULL (denormalised for tenant filtering)
version	int	NOT NULL, ≥ 1
status	text	NOT NULL, CHECK in (`draft`, `published`)
definition_json	jsonb	NOT NULL
schema_version	int	NOT NULL (definition format version, currently 1)
checksum	text	NULL until published; SHA-256 hex of canonical JSON
created_by	uuid	FK users
published_at	timestamptz	NULL
Unique `(workflow_id, version)`. CHECK: `status='published'` ⇒ `checksum IS NOT NULL AND published_at IS NOT NULL`. A trigger `forbid_published_version_update` raises on any UPDATE or DELETE of a row whose OLD.status is `published` (immutability enforced by the database). Only one draft per workflow at a time: partial unique index `(workflow_id) WHERE status='draft'`.		

triggers (phase 4 for manual metadata, phase 9 for webhook)

Column	Type	Constraints
org_id	uuid	FK, NOT NULL
workflow_id	uuid	FK, NOT NULL
kind	text	CHECK in (`webhook`) (manual runs have no trigger row)
credential_id	uuid	FK integration_credentials, NOT NULL (holds the HMAC secret)
enabled	boolean	NOT NULL DEFAULT true
updated_at	timestamptz	

integration_credentials (phase 5 table, phase 9 encryption)

Column	Type	Constraints
org_id	uuid	FK, NOT NULL
provider	text	NOT NULL, `^[a-z0-9_-]{2,40}$`
name	text	NOT NULL, unique `(org_id, name)`
encrypted_secret	bytea	NOT NULL (AES-256-GCM, nonce prepended)
key_id	text	NOT NULL (which master key encrypted it)
allowed_hosts	text[]	NOT NULL DEFAULT '{}' (exact hostnames)
permission_scopes	text[]	NOT NULL DEFAULT '{}'
rotated_at	timestamptz	NULL
Secrets are write-only through the API: never returned after creation.		

workflow_runs (phase 4)

Column	Type	Constraints
org_id	uuid	FK, NOT NULL
workflow_id	uuid	FK, NOT NULL
version_id	uuid	FK workflow_versions, NOT NULL (pinned)
state	text	NOT NULL, CHECK in (`QUEUED`,`RUNNING`,`WAITING_APPROVAL`,`SUCCEEDED`,`FAILED`,`CANCELLED`)
trigger_kind	text	NOT NULL, CHECK in (`manual`,`webhook`)
trigger_id	uuid	NULL, FK triggers
idempotency_key	text	NULL
request_fingerprint	text	NULL (SHA-256 of canonical request body, to detect key reuse with a different body)
inputs	jsonb	NOT NULL DEFAULT '{}'
context	jsonb	NOT NULL DEFAULT '{}' (map `step_id → output`)
outputs	jsonb	NULL (output of the last step on success)
current_step_id	text	NULL
error_code	text	NULL
error_detail	text	NULL (safe, redacted)
cancel_requested	boolean	NOT NULL DEFAULT false
lease_owner	text	NULL (worker id)
lease_expires_at	timestamptz	NULL
heartbeat_at	timestamptz	NULL
next_attempt_at	timestamptz	NULL

Column	Type	Constraints
attempt_epoch	int	NOT NULL DEFAULT 0 (incremented on each claim; a fencing token)
created_by	uuid	NULL, FK users
started_at, finished_at	timestamptz	NULL
updated_at	timestamptz	
Constraints: partial unique `(org_id, idempotency_key) WHERE idempotency_key IS NOT NULL`. Indexes: `(org_id, created_at DESC, id DESC)`; `(state, next_attempt_at)`; `(org_id, state)`; `(lease_expires_at) WHERE state='RUNNING'`.		

step_attempts (phase 4)

Column	Type	Constraints
run_id	uuid	FK, NOT NULL
org_id	uuid	NOT NULL
step_id	text	NOT NULL
step_type	text	NOT NULL
attempt_no	int	NOT NULL, ≥ 1
status	text	NOT NULL, CHECK in (`RUNNING`, `SUCCEEDED`, `FAILED`)
input	jsonb	NULL (redacted, ≤ 64 KB)
output	jsonb	NULL (redacted, ≤ 64 KB)
error_code	text	NULL
error_detail	text	NULL
retryable	boolean	NULL
epoch	int	NOT NULL (run `attempt_epoch` at start)
started_at	timestamptz	NOT NULL
ended_at	timestamptz	NULL
duration_ms	int	NULL
Unique `(run_id, step_id, attempt_no)`. Index `(run_id, started_at)`.		

approval_requests (phase 7)

Column	Type	Constraints
org_id	uuid	NOT NULL
run_id	uuid	FK, NOT NULL
step_id	text	NOT NULL
version_id	uuid	FK, NOT NULL (bound version)
assigned_role	text	NOT NULL, CHECK in (`reviewer`,`admin`,`owner`)
state	text	NOT NULL, CHECK in (`PENDING`,`APPROVED`,`REJECTED`,`EXPIRED`,`CANCELLED`)
summary	jsonb	NOT NULL (what the reviewer sees; redacted)
expires_at	timestamptz	NOT NULL
decided_by	uuid	NULL, FK users
decided_at	timestamptz	NULL
decision_comment	text	NULL, ≤ 1000
Partial unique `(run_id, step_id) WHERE state='PENDING'`. Index `(org_id, state, expires_at)`. CHECK: state in (APPROVED, REJECTED) ⇒ `decided_by` and `decided_at` NOT NULL.		

tool_effects (phase 5)

Column	Type	Constraints
org_id	uuid	NOT NULL
run_id	uuid	FK, NOT NULL
step_id	text	NOT NULL
provider	text	NOT NULL (credential provider name or host)
idempotency_key	text	NOT NULL (`{run_id}:{step_id}`)
state	text	NOT NULL, CHECK in (`INTENDED`,`COMMITTED`,`FAILED`,`AMBIGUOUS`)
request_hash	text	NOT NULL
external_ref	text	NULL
response_summary	jsonb	NULL
updated_at	timestamptz	
Unique `(provider, idempotency_key)`.		

outbox_events (phase 4)

Column	Type	Constraints
aggregate_type	text	NOT NULL (`run`)
aggregate_id	uuid	NOT NULL
event_type	text	NOT NULL, CHECK in (`RunRequested`,`RunResumeRequested`,`RunCancelRequested`)
schema_version	int	NOT NULL DEFAULT 1
payload	jsonb	NOT NULL
published_at	timestamptz	NULL
publish_attempts	int	NOT NULL DEFAULT 0
next_publish_at	timestamptz	NOT NULL DEFAULT now()
Partial index `(next_publish_at) WHERE published_at IS NULL`.		

usage_records (phase 6)

Column	Type	Constraints
org_id	uuid	NOT NULL
run_id	uuid	FK, NOT NULL
step_id	text	NOT NULL
attempt_id	uuid	FK step_attempts
provider	text	NOT NULL (`openrouter`, `fake`)
model_name	text	NOT NULL
prompt_tokens, completion_tokens, total_tokens	int	NOT NULL ≥ 0
estimated_cost_micro_usd	bigint	NOT NULL ≥ 0 (tokens × configured price; used for budgets)
billed_cost_micro_usd	bigint	NOT NULL DEFAULT 0 (free models: 0)
latency_ms	int	NOT NULL
prompt_template_id, prompt_template_version	text, int	NOT NULL
outcome	text	NOT NULL, CHECK in (`ok`,`invalid_output`,`provider_error`,`rate_limited`)
Index `(org_id, created_at DESC)`.		

budget_reservations (phase 9; the table is created in phase 9, phase 6 uses only usage_records)

Column	Type	Constraints
org_id	uuid	NOT NULL
run_id	uuid	NOT NULL
step_id	text	NOT NULL
reserved_micro_usd	bigint	NOT NULL ≥ 0
settled_micro_usd	bigint	NULL
state	text	CHECK in (`RESERVED`,`SETTLED`,`RELEASED`)
settled_at	timestamptz	NULL
Unique `(run_id, step_id)`.		

audit_events (phase 7)

Column	Type	Constraints
org_id	uuid	NULL (auth events have none)
actor_user_id	uuid	NULL
actor_type	text	NOT NULL, CHECK in (`user`,`system`,`webhook`)
action	text	NOT NULL (e.g. `approval.decided`)
target_type	text	NOT NULL
target_id	uuid	NULL
request_id	text	NULL
redacted_metadata	jsonb	NOT NULL DEFAULT '{}'
Append-only: a trigger raises on UPDATE and DELETE. Index `(org_id, created_at DESC)`.		

Migration order (Alembic revision names)

1. `0001_identity_orgs` : users, refresh_tokens, organizations, memberships
2. `0002_workflows` : workflows, workflow_versions (+ immutability trigger)
3. `0003_runs_outbox` : workflow_runs, step_attempts, outbox_events
4. `0004_tools_credentials` : integration_credentials, tool_effects
5. `0005_usage` : usage_records
6. `0006_approvals_audit` : approval_requests, audit_events (+ append-only trigger)
7. `0007_triggers_budgets` : triggers, budget_reservations

`triggers` references `workflow_runs.trigger_id`. **Rule:** migration `0003` creates `workflow_runs.trigger_id uuid NULL` with no FK; migration `0007` creates `triggers` and then adds the FK.

4. State machines

Run (`workflow_runs.state`)

#	From	Event	To	Actor	Guard	DB update (single
R1	—	create	QUEUED	API	caller has `run.trigger`; org under concurrency cap; version published	INSERT run + INSER transaction
R2	QUEUED	claim	RUNNING	worker	`next_attempt_at <= now()` or NULL	`UPDATE … SET sta lease_expires_at= attempt_epoch=att started_at=COALES id=:id AND state=`
R3	RUNNING	reclaim	RUNNING	worker	`lease_expires_at < now()`	same as R2 but `WHE AND lease_expires`
R4	RUNNING	needs approval	WAITING_APPROVAL	worker	epoch matches	`UPDATE … SET sta lease_owner=NULL, current_step_id= state='RUNNING' A`
R5	WAITING_APPROVAL	approved	QUEUED	API (decision)	approval decided APPROVED in the same transaction	`UPDATE … SET sta next_attempt_at=n state='WAITING_AP`
R6	RUNNING	all steps done	SUCCEEDED	worker	epoch matches; `cancel_requested=false`	`UPDATE … SET sta finished_at=now() AND state='RUNNIN`
R7	RUNNING	step failed finally	FAILED	worker	epoch matches	same shape, with `e`
R8	WAITING_APPROVAL	rejected / expired	FAILED	API / sweeper	approval REJECTED or EXPIRED	`UPDATE … SET sta error_code='APPRO WHERE id=:id AND`
R9	QUEUED, WAITING_APPROVAL	cancel	CANCELLED	API	`run.cancel`	`UPDATE … SET sta cancel_requested= id=:id AND state ('QUEUED','WAITIN`
R10	RUNNING	cancel requested	CANCELLED	worker (at next step boundary)	`cancel_requested=true`, epoch matches	`UPDATE … SET sta state='RUNNING' A`
R11	FAILED	retry (manual)	QUEUED	API	`run.retry`; error is not `CANCELLED`	`UPDATE … SET sta error_detail=NULL next_attempt_at=n state='FAILED'`

Terminal states: `SUCCEEDED`, `CANCELLED`. `FAILED` is terminal except for manual retry (R11). Any `UPDATE` with rowcount 0 means the guard failed → return `409 INVALID_STATE_TRANSITION` (API) or abandon the work (worker).

Cancel vs complete race. R6 and R10 and R9 all carry state guards. Whichever commits first wins; the loser sees rowcount 0. A provider effect that already committed cannot be undone; the run still ends CANCELLED and the `tool_effects` ledger shows the effect.

Step attempt (`step_attempts.status`)

`RUNNING → SUCCEEDED | FAILED`. A retry is a **new row** with `attempt_no+1`. Rows are never mutated after `ended_at` is set.

Approval (`approval_requests.state`)

From	Event	To	Guarded statement
PENDING	approve	APPROVED	`UPDATE … SET state='APPROVED', decided_by=:u, decided_at=now() WHERE id=:id AND state='PENDING' AND expires_at > now()`
PENDING	reject	REJECTED	same, with `'REJECTED'`
PENDING	expire	EXPIRED	`UPDATE … SET state='EXPIRED' WHERE id=:id AND state='PENDING' AND expires_at <= now()` (sweeper)
PENDING	run cancelled	CANCELLED	in the cancel transaction

Outbox (`published_at`)

`unpublished (published_at IS NULL) → published`. The publisher selects `WHERE published_at IS NULL AND next_publish_at <= now() ORDER BY id LIMIT 100 FOR UPDATE SKIP LOCKED`, publishes with confirm, then sets `published_at=now()`. On failure: `publish_attempts+1`, `next_publish_at = now() + backoff`.

5. Workflow definition format (schema_version 1)

```
{
  "schema_version": 1,
  "name": "Support ticket triage",
  "inputs_schema": {
    "type": "object",
    "required": ["ticket_id", "body"],
    "properties": {"ticket_id": {"type": "string"}, "body": {"type": "string", "maxLength":
4000}},
    "additionalProperties": false
  },
  "start": "classify",
  "steps": [
    {"id": "classify", "type": "llm_classify",
     "config": {"prompt_template_id": "ticket_classify", "input": "{{ inputs.body }}",
                "labels": ["billing", "bug", "other"], "max_tokens": 100},
     "next": "route"},
    {"id": "route", "type": "condition",
     "config": {"branches": [{"when": {"op": "eq", "left":
"{{ steps.classify.output.label }}", "right": "billing"}, "next": "approve"}],
                "else": "done"}},
    {"id": "approve", "type": "approval",
```

```
     "config": {"assigned_role": "reviewer", "expires_in_seconds": 86400,
                "summary": "Create CRM ticket for {{ inputs.ticket_id }}"},
     "next": "crm"},
    {"id": "crm", "type": "http_request",
     "config": {"credential_id": "…uuid…", "method": "POST", "url": "https://
crm.example.com/tickets",
                "headers": {"Content-Type": "application/json"},
                "body": {"ticket_id": "{{ inputs.ticket_id }}"}, "timeout_seconds": 10,
                "effect": "write", "max_attempts": 3},
     "next": "done"},
    {"id": "done", "type": "set_data", "config": {"values": {"status": "complete"}},
"next": null}
  ]
}
```

Rules - `id`: `^[a-z][a-z0-9_]{0,39}$`, unique. Max 50 steps. `start` must name a step. - Every step except `condition` has `next` (a step id or `null` = end of the workflow). `condition` has `config.branches` (1–5 entries, each `{when, next}`) and `config.else` (step id or null). Branches are evaluated in order; first match wins; no match uses `else`. - Graph must be a DAG, every step reachable from `start`, every referenced step must exist. At least one terminating path. Cycles → `GRAPH_CYCLE`. - **Templating**: `{{ path }}` only. Allowed roots: `inputs.<field>` and `steps.<step_id>.output.<field>`. Dotted paths and numeric indexes (`items.0.name`) only. No functions, no code. A string that is exactly one placeholder keeps the JSON type of the value; otherwise placeholders are string-interpolated. A template may reference only steps that are **ancestors** of the current step in the graph (validated at publish → `UNKNOWN_REFERENCE`). - Condition `when`: `{"op": "eq|neq|gt|gte|lt|lte|in|exists", "left": <template or literal>, "right": <template or literal>}` (`exists` has `left` only).

Step types and `config` (unknown config keys are rejected) | type | Required config | Optional config (default) | Output (`steps.<id>.output`) | |---|---|---|---| | `set_data` | `values` (object of templates) | — | the resolved `values` object | | `condition` | `branches`, `else` | — | `{"matched": <index or "else">}` | | `http_request` | `method` (GET, POST, PUT, PATCH, DELETE), `url` (https only) | `credential_id`, `headers` (`{}`; may not contain Authorization, Cookie, Proxy-Authorization, Host), `body` (null), `timeout_seconds` (10, 1–30), `effect` (`read`/`write`; default `read` for GET, else `write`), `max_attempts` (3, 1–5) | `{"status": int, "body": json|text (≤ 64 KB), "headers": {allowlisted}}` | | `llm_classify` | `prompt_template_id`, `input`, `labels` (2–20 strings) | `max_tokens` (100, 1–500) | `{"label": one of labels, "confidence": 0–1 or null}` | | `llm_transform` | `prompt_template_id`, `input`, `output_schema` (JSON Schema object, max 4 KB, depth ≤ 4) | `max_tokens` (400, 1–1500) | the validated object | | `approval` | `assigned_role` (reviewer, admin, owner), `summary` (template) | `expires_in_seconds` (86400, 60–604800) | `{"decision": "approved", "decided_by": uuid, "decided_at": iso}` (only reached if approved) |

`http_request` with `effect="write"` requires the **same run** to have passed through an `approval` step earlier in the graph, if the credential's `permission_scopes` contains `irreversible` (validated at publish → `APPROVAL_REQUIRED_FOR_IRREVERSIBLE`).

Prompt templates live in the repository as `app/ai/prompts/<id>.yaml` (`id`, `version`, `system`, `user` with `{{ input }}` and `{{ labels }}` placeholders). The workflow references them by id. Prompt text is never stored in the database or logs.

6. Execution algorithm (worker)

Defined precisely in `spec/phase-04.md` and `spec/phase-05.md`. Global parameters:

Parameter	Value
Lease duration	60 s
Heartbeat interval	15 s (extends `lease_expires_at` to `now()+60 s` only if `attempt_epoch` still matches)
Sweeper interval	30 s
Outbox publisher poll	1 s idle sleep, batch 100
Step max attempts	`config.max_attempts` (default 3)
Backoff	`delay = random(0, min(60, 2 * 2^(attempt_no-1)))` seconds (full jitter); `Retry-After` header wins if larger, capped at 120 s
Max steps executed per run	100 (guards against definition mistakes)
Max step output stored	64 KB (truncated with a marker `{"_truncated": true}`)
Default per-org concurrent runs	5; the cap counts runs in `QUEUED` or `RUNNING` (runs in `WAITING_APPROVAL` do not consume a slot)
Celery	`acks_late=True`, `reject_on_worker_lost=True`, `worker_prefetch_multiplier=1`, `task_acks_on_failure_or_timeout=False`

Resume rule. When a run is claimed, the worker rebuilds `context` from its `context` column and continues at `current_step_id` (or `start`). A step whose latest attempt is `SUCCEEDED` is not re-executed; its stored output is used.

Fencing. Every write the worker makes to `workflow_runs` or `step_attempts` includes `AND attempt_epoch = :epoch`. A worker that lost its lease gets rowcount 0 and must stop without further effects.

7. Error catalog

Code	HTTP	When
`VALIDATION_ERROR`	422	Request body, query or path failed validation
`BAD_REQUEST`	400	Malformed JSON, bad cursor, bad header format
`UNAUTHENTICATED`	401	Missing, malformed, expired or invalid access token
`INVALID_CREDENTIALS`	401	Wrong email or password (same message for both)
`FORBIDDEN`	403	Member of the org but lacks the permission
`NOT_FOUND`	404	Object missing **or** in another tenant; unknown route
`METHOD_NOT_ALLOWED`	405	Wrong HTTP method
`EMAIL_TAKEN`	409	Signup with an existing email
`CONFLICT`	409	Unique constraint conflict (slug, name, member exists)
`INVALID_STATE_TRANSITION`	409	State guard failed (cancel finished run, decide twice, …)

Code	HTTP	When
`IDEMPOTENCY_KEY_REUSED`	409	Same key, different body
`VERSION_NOT_PUBLISHED`	409	Run requested against a draft / archived workflow
`DRAFT_EXISTS`	409	Creating a draft when one exists
`LAST_OWNER`	409	Action would leave an org without an owner
`GRAPH_CYCLE`	422	Definition contains a cycle (`errors` lists the step ids)
`GRAPH_UNREACHABLE_STEP`	422	Step not reachable from `start`
`GRAPH_MISSING_STEP`	422	`next`/`start`/branch references an unknown step
`UNKNOWN_REFERENCE`	422	Template references a non-ancestor step or unknown input
`TYPE_MISMATCH`	422	Condition or mapping type clearly invalid
`INVALID_STEP_CONFIG`	422	Unknown key, out-of-range value, bad schema
`FORBIDDEN_TOOL_PERMISSION`	422	Step uses a host or credential not allowed
`APPROVAL_REQUIRED_FOR_IRREVERSIBLE`	422	See §5
`PAYLOAD_TOO_LARGE`	413	Body over `MAX_REQUEST_BYTES`
`RATE_LIMITED`	429	API rate limit hit (`Retry-After` header set)
`CONCURRENCY_LIMIT`	429	Org at `max_concurrent_runs`
`BUDGET_EXCEEDED`	402	Org budget exhausted (run request)
`INTERNAL_ERROR`	500	Unhandled error (generic message)
`SERVICE_UNAVAILABLE`	503	`/ready` fails, or the DB is unavailable
`WEBHOOK_SIGNATURE_INVALID`	401	Signature missing or wrong
`WEBHOOK_REPLAY`	401	Timestamp outside the window or signature reused

Run `error_code` values (stored on the run or attempt): `STEP_TIMEOUT`, `STEP_HTTP_ERROR`, `STEP_RETRIES_EXHAUSTED`, `TOOL_EFFECT_AMBIGUOUS`, `LLM_INVALID_OUTPUT`, `LLM_RATE_LIMITED`, `LLM_PROVIDER_ERROR`, `LLM_NON_FREE_MODEL`, `APPROVAL_REJECTED`, `APPROVAL_EXPIRED`, `MAX_STEPS_EXCEEDED`, `BUDGET_EXCEEDED`, `EGRESS_BLOCKED`, `INTERNAL_ERROR`.

8. API surface (all paths under `/v1`)

Unless stated: `Authorization` required; responses are JSON; errors per §7. `{org_id}` routes check membership first. Phase = when the endpoint is implemented. Full request/response schemas are in the phase specs.

Phase	Method and path	Permission	Success
1	`GET /health` (no `/v1`, no auth)	public	200
1	`GET /ready` (no `/v1`, no auth)	public	200 / 503
2	`POST /v1/auth/signup`	public	201
2	`POST /v1/auth/login`	public	200
2	`POST /v1/auth/refresh`	refresh token	200
2	`POST /v1/auth/logout`	refresh token	204

Phase	Method and path	Permission	Success
2	`GET /v1/me`	any user	200
2	`POST /v1/organizations`	any user	201
2	`GET /v1/organizations`	any user	200 (mine)
2	`GET /v1/organizations/{org_id}`	member	200
2	`GET /v1/organizations/{org_id}/members`	member	200
2	`POST /v1/organizations/{org_id}/members`	`member.manage`	201
2	`PATCH /v1/organizations/{org_id}/members/{user_id}`	`member.manage`	200
2	`POST /v1/organizations/{org_id}/workflows`	`workflow.write`	201
2	`GET /v1/organizations/{org_id}/workflows`	`workflow.read`	200
2	`GET /v1/workflows/{id}`	`workflow.read`	200
3	`POST /v1/workflows/{id}/versions`	`workflow.write`	201 (draft)
3	`PUT /v1/workflows/{id}/versions/{n}` (drafts only)	`workflow.write`	200
3	`GET /v1/workflows/{id}/versions` / `…/{n}`	`workflow.read`	200
3	`POST /v1/workflows/{id}/validate`	`workflow.write`	200
3	`POST /v1/workflows/{id}/publish`	`workflow.publish`	200
4	`POST /v1/workflows/{id}/runs`	`run.trigger`	**202**
4	`GET /v1/organizations/{org_id}/runs`	`run.read`	200
4	`GET /v1/runs/{id}`	`run.read`	200
4	`GET /v1/runs/{id}/steps`	`run.read`	200
5	`POST /v1/runs/{id}/cancel`	`run.cancel`	200
5	`POST /v1/runs/{id}/retry`	`run.retry`	202
5	`POST /v1/organizations/{org_id}/credentials`	`credential.manage`	201 (no secret returned)
5	`GET /v1/organizations/{org_id}/credentials`	`credential.manage`	200 (no secrets)
7	`GET /v1/organizations/{org_id}/approvals`	`approval.read`	200
7	`GET /v1/approvals/{id}`	`approval.read`	200
7	`POST /v1/approvals/{id}/decisions`	`approval.decide`	200
7	`GET /v1/organizations/{org_id}/audit-events`	`audit.read`	200
8	`GET /v1/organizations/{org_id}/usage?from=&to=`	`usage.read`	200
8	`GET /metrics` (no `/v1`; network-restricted)	internal	200
9	`POST /v1/workflows/{id}/triggers`	`workflow.write`	201
9	`POST /v1/triggers/webhooks/{trigger_id}`	HMAC signature	202

Deliberate deviation from the source roadmap: the roadmap lists `GET /v1/usage`. This spec scopes it to `/v1/organizations/{org_id}/usage` so tenancy is explicit in the URL. The source's `POST /v1/organizations/{org_id}/workflows` is kept.

9. Configuration reference (environment variables)

Read through `app/core/config.py` (pydantic-settings). Names are exact. `.env.example` is committed with placeholders only.

Variable	Type	Default	Meaning
`APP_ENV`	`dev|test|prod`	`dev`	Enables strict `prod`
`LOG_LEVEL`	str	`INFO`	
`API_CORS_ORIGINS`	comma list	`http://localhost:5173`	Exact allowli
`MAX_REQUEST_BYTES`	int	`1048576`	Body size lim
`DATABASE_URL`	str	`postgresql+asyncpg://flowforge:flowforge@localhost:5432/flowforge`	
`DB_POOL_SIZE` / `DB_MAX_OVERFLOW`	int	`10` / `10`	
`TEST_DATABASE_URL`	str	same server, db `flowforge_test`	Integration t
`JWT_SECRET`	str (≥ 32 chars)	none (required)	HS256 signi
`JWT_ISSUER` / `JWT_AUDIENCE`	str	`flowforge` / `flowforge-api`	Verified on e
`ACCESS_TOKEN_TTL_SECONDS`	int	`900`	
`REFRESH_TOKEN_TTL_SECONDS`	int	`604800`	
`PASSWORD_MIN_LENGTH`	int	`12`	
`RABBITMQ_URL`	str	`amqp://flowforge:flowforge@localhost:5672//`	
`CELERY_TASK_QUEUE`	str	`runs.execute`	
`LEASE_SECONDS` / `HEARTBEAT_SECONDS` / `SWEEPER_INTERVAL_SECONDS`	int	`60` / `15` / `30`	
`EGRESS_ALLOWED_HOSTS`	comma list	empty	Hosts usable `http_reque` credential
`EGRESS_BLOCK_PRIVATE`	bool	`true`	Block private local, metad
`LLM_PROVIDER`	`fake|openrouter`	`fake`	
`OPENROUTER_API_KEY`	secret	empty	Never logge
`OPENROUTER_BASE_URL`	str	`https://openrouter.ai/api/v1`	
`LLM_MODEL`	str	`openrouter/free`	Must end wi equal `openr`
`LLM_FALLBACK_MODELS`	comma list	empty	Each must e
`LLM_TIMEOUT_SECONDS`	int	`30`	
`LLM_FREE_RPM` / `LLM_FREE_RPD`	int	`20` / `50`	Local limiter RPD after $1
`LLM_PRICE_PER_1K_TOKENS_MICRO_USD`	int	`2000`	Used for `estimated_` (budget dem

Variable	Type	Default	Meaning
`SECRETS_MASTER_KEYS`	`key_id:base64key` list	none (phase 9)	AES-256 key active one
`WEBHOOK_TIMESTAMP_TOLERANCE_SECONDS`	int	`300`	
`OTEL_EXPORTER_OTLP_ENDPOINT`	str	empty (disabled)	Phase 8
`OTEL_SERVICE_NAME`	str	per process	`flowforge-` `-scheduler`
`METRICS_ENABLED`	bool	`true`	

10. Security rules (exact)

- **Passwords:** min 12 chars, max 128, argon2id (library defaults), compared in constant time. Same `INVALID_CREDENTIALS` response for unknown email and wrong password.
- **Access token (JWT HS256):** claims `sub` (user id), `iat`, `exp`, `iss`, `aud`, `jti`. 15 min lifetime. Verified: signature, `exp`, `iss`, `aud`. **No org or role claim**: roles are read from the database on each request.
- **Refresh token:** 256-bit random, only its SHA-256 stored, rotation on each use (old marked `revoked_at`, `replaced_by` set); reuse of a revoked token revokes the whole chain.
- **Storage in the SPA:** access token in memory only; refresh token in an `HttpOnly; Secure; SameSite=Strict` cookie scoped to `/v1/auth` (set by the API).
- **Rate limits (phase 9):** login 10/min per IP+email, signup 5/hour per IP, other API 300/min per user. Over limit → `429 RATE_LIMITED` with `Retry-After`.
- **Egress blocklist** (checked on every resolved IP, including after redirects; redirects are **not followed** in MVP): `0.0.0.0/8`, `10.0.0.0/8`, `100.64.0.0/10`, `127.0.0.0/8`, `169.254.0.0/16`, `172.16.0.0/12`, `192.0.0.0/24`, `192.168.0.0/16`, `198.18.0.0/15`, `224.0.0.0/4`, `240.0.0.0/4`, `::1/128`, `fc00::/7`, `fe80::/10`, `::ffff:0:0/96` (IPv4-mapped). Only `https` URLs, ports 443 (and 8443), hostnames from the credential's `allowed_hosts` or `EGRESS_ALLOWED_HOSTS`. Connect to the validated IP while keeping the original `Host`/SNI.
- **Webhook signature:** header `X-FlowForge-Timestamp` (unix seconds) and `X-FlowForge-Signature: v1=<hex>` where hex = HMAC-SHA256(secret, `"{timestamp}.{raw_body}"`). Reject if the timestamp is outside ±300 s, if the signature mismatches (constant-time), or if `(trigger_id, signature)` was already used inside the window.
- **Redaction:** keys matching `(?i)(password|secret|token|authorization|api[_-]?key|cookie)` are replaced with `"***"` in logs, step inputs/outputs and audit metadata. Credentials are never passed to templates, prompts or models.
- **LLM:** model output is untrusted; validated against the step's schema; tool arguments come only from the workflow definition, never from model output.

11. Infrastructure reference

Docker Compose services (`compose.yaml`; dev ports on `127.0.0.1` only):

Service	Image / build	Port	Healthcheck	Phase
`postgres`	`postgres:<pinned>`	5432	`pg_isready -U flowforge`	2
`rabbitmq`	`rabbitmq:<pinned>-management`	5672, 15672		4

Service	Image / build	Port	Healthcheck	Phase
			`rabbitmq-diagnostics -q ping`	
`api`	build `infra/docker/api.Dockerfile`	8000	`GET /ready`	1
`worker`	same image, command `celery -A app.workers.celery_app worker`	—	`celery inspect ping`	4
`scheduler`	same image, command `python -m app.workers.scheduler` (outbox publisher + sweeper + approval expiry)	—	process alive + heartbeat file	4
`frontend`	build `frontend/Dockerfile` (prod) or Vite dev server on host	5173	HTTP 200	1
`otel-collector`, `jaeger`	pinned	4317, 16686	—	8
`prometheus`, `grafana`	pinned	9090, 3000	—	8

RabbitMQ topology (declared by the publisher/worker at start-up, idempotently): exchange `flowforge.runs` (direct, durable), queue `runs.execute` (durable, quorum, `x-dead-letter-exchange=flowforge.dlx`, `x-delivery-limit=5`), binding key `run.execute`; exchange `flowforge.dlx` (fanout) → queue `runs.dead`. Message body JSON: `{"event_id": uuid, "event_type": "...", "schema_version": 1, "run_id": uuid, "org_id": uuid, "trace_context": {...}}`, `delivery_mode=2`, `message_id=event_id`.

12. Dependency set

Latest versions found on 2026-10-25 with `pip index versions` and `npm view`. **Not yet confirmed to install together on Python 3.14.4.** Phase 1 task P1-S03 runs `pip-compile` and records any version that must be lowered. Pin the result in `requirements.txt` and `frontend/package-lock.json`; this table is the starting point, not the lock.

Runtime	Version on this machine
Python	3.14.4
Node / npm	24.21.0 / 11.19.0
Docker Compose	5.6.1

Backend (`requirements.in`) `fastapi==0.162.0`, `uvicorn[standard]==0.54.0`, `pydantic==2.14.1`, `pydantic-settings==2.16.1`, `email-validator==2.3.0`, `sqlalchemy[asyncio]==2.1.6`, `asyncpg==0.32.0`, `alembic==1.20.1`, `celery==5.6.3`, `kombu==5.6.2`, `httpx==0.28.1`, `pyjwt==2.15.1`, `argon2-cffi==25.1.0`, `cryptography==50.0.2`, `orjson==3.13.0`, `structlog==26.1.0`, `prometheus-client==0.26.0`, `opentelemetry-api==1.45.1`, `opentelemetry-sdk==1.45.1`, `jsonschema` (version to be looked up in P1-S03). **Dev** (`requirements-dev.in`): `pytest==9.1.1`, `pytest-asyncio==1.4.0`, `hypothesis==6.170.9`, `testcontainers==4.15.0`, `ruff==0.17.2`, `mypy==2.4.0`, `pip-tools==7.6.2`, `pre-commit`. **Frontend** (`frontend/package.json`): `react@19.3.1`, `react-dom`, `vite@8.3.5`, `typescript@7.0.2`, `@tanstack/react-query@5.104.5`, `react-router-dom@7.18.4`, `vitest@5.0.5`, `@playwright/test@1.64.1`, `openapi-typescript@7.13.0`, `eslint@10.13.0`. **Docker images:** tags for

PostgreSQL, RabbitMQ, Prometheus, Grafana, Jaeger and the OTel collector have **not** been looked up. P2-S01 and later phases pick current stable tags with `docker pull` and record the digests.

13. Backlog (explicitly NOT in this spec)

Cron triggers, templates, version rollback, fine-grained RBAC, SSE live updates, per-org fairness, budget alerting, searchable run history, dry-run replay, LangGraph sub-agent, MCP, RAG, provider failover, sagas, Temporal prototype, data residency, audit export, chaos/soak harness, visual node canvas.